

CYBERSECURITY CASE STUDY

Container Security, SBOM and Detection Engineering

Docker Bench • Syft • Grype • CISA KEV • Sigma

Alshaima Syed

Cloud Security | Vulnerability Management | Detection Engineering

Executive summary

This case study combines container hardening, software supply-chain visibility, vulnerability analysis and detection engineering. Docker Bench assessed host controls; Syft generated a CycloneDX SBOM for an Ubuntu image; Gype identified known vulnerabilities; CISA KEV context supported prioritization; and Sigma analytics addressed OT scheduled-task behavior and MFA push fatigue.

Outcome

The workflow produced a 2,393-component SBOM and identified 114 vulnerabilities: 1 High, 61 Medium, 44 Low and 8 Negligible, with no Critical findings. The exercise then translated technical findings into remediation and detection recommendations.

Environment	Docker Desktop and Ubuntu 22.04 container image on Windows 11.
Core tools	Docker Bench Security, Syft, Gype, CycloneDX, CISA KEV and Sigma.
Security focus	Hardening, SBOM governance, vulnerability prioritization and detection engineering.
Detection cases	Industroyer2-style scheduled-task behavior and MFA push fatigue.
Safety boundary	Analysis used public tools, a standard container image and defensive detection content.

Assurance pipeline

The project followed a repeatable chain: assess configuration, inventory components, identify exposures, add exploitation context, prioritize remediation and design monitoring for behaviors that preventive controls may miss.

1. Harden	Run CIS-aligned Docker checks and review exceptions.
2. Inventory	Generate a machine-readable CycloneDX SBOM with Syft.
3. Scan	Evaluate the SBOM with Gype and record severity/remediation data.
4. Prioritize	Confirm asset relevance and check CISA KEV before setting action.
5. Detect	Create/tune Sigma rules and verify required telemetry.

Container hardening

Docker Bench Security highlighted configuration items requiring review, including daemon exposure, privilege boundaries, sensitive socket ownership and operational logging. Findings were treated as risk signals rather than automatically accepted failures; applicability depends on host role and compensating controls.

```
C:\Users\shaim>docker pull docker/docker-bench-security
Using default tag: latest
latest: Pulling from docker/docker-bench-security
378ed37ea5ff: Pull complete
48fe0d48816d: Pull complete
cd784148e348: Pull complete
164e5e0f48c5: Pull complete
Digest: sha256:ddbdf4f86af4405da4a8a7b7cc62bb63bfeb75e85bf22d2ece70c204d7cfabb8
Status: Downloaded newer image for docker/docker-bench-security:latest
docker.io/docker/docker-bench-security:latest

What's next:
View a summary of image vulnerabilities and recommendations → docker scout quickview docker/docker-bench-security
```

Figure 1. Docker Bench Security execution in the authorized lab environment.

SBOM generation

Syft generated a CycloneDX inventory for the Ubuntu image. The output created component-level visibility needed to associate installed packages with vulnerability intelligence and vendor remediation.

```
C:\Users\shaim>docker pull ubuntu:22.04
22.04: Pulling from library/ubuntu
Digest: sha256:4f838adc7181d9039ac795a7d0aba05a9bd9ecd480d294483169c5def983b64d
Status: Image is up to date for ubuntu:22.04
docker.io/library/ubuntu:22.04
```

Figure 2. Syft workflow used to produce the CycloneDX SBOM.

Observed SBOM scale

Format	CycloneDX
Components	2,393 software components
Operational value	Faster impact assessment, vendor inquiry and patch verification.

Vulnerability analysis

Critical	0
High	1
Medium	61
Low	44
Negligible	8
Total	114

```
PS C:\Users\shaim\Documents> Get-Content .\grype_results.txt -First 20
NAME          INSTALLED          FIXED IN          TYPE  VULNERABILITY  SEVERITY  EPSS          RISK
login          1:4.8.1-2ubuntu2.2 deb             CVE-2024-56433  Low      6.0% (90th)   1.8
passwd         1:4.8.1-2ubuntu2.2 deb             CVE-2024-56433  Low      6.0% (90th)   1.8
perl-base     5.34.0-3ubuntu1.5  (won't fix)     deb             CVE-2023-31486  Medium    0.8% (74th)   0.4
libgnutls30    3.7.3-4ubuntu1.8   3.7.3-4ubuntu1.9 deb             CVE-2026-42009  Medium    0.7% (72nd)   0.4
libgcrypt20    1.9.4-3ubuntu3     deb             CVE-2024-2236   Low      0.7% (71st)   0.2
libssl3        3.0.2-0ubuntu1.23  (won't fix)     deb             CVE-2024-41996  Low      0.6% (70th)   0.2
libsystemd0    249.11-0ubuntu3.20 249.11-0ubuntu3.21 deb             CVE-2023-7008   Low      0.5% (65th)   0.1
libudev1       249.11-0ubuntu3.20 249.11-0ubuntu3.21 deb             CVE-2023-7008   Low      0.5% (65th)   0.1
libgnutls30    3.7.3-4ubuntu1.8   3.7.3-4ubuntu1.9 deb             CVE-2026-42015  Medium    0.2% (48th)   0.1
libgnutls30    3.7.3-4ubuntu1.8   3.7.3-4ubuntu1.9 deb             CVE-2026-5260   Medium    0.2% (46th)   0.1
libgnutls30    3.7.3-4ubuntu1.8   3.7.3-4ubuntu1.9 deb             CVE-2026-3833   Medium    0.2% (38th)   < 0.1
libgssapi-krb5-2 1.19.2-2ubuntu0.7  (won't fix)     deb             CVE-2018-5709   Negligible 1.6% (82nd)   < 0.1
libk5crypto3    1.19.2-2ubuntu0.7  (won't fix)     deb             CVE-2018-5709   Negligible 1.6% (82nd)   < 0.1
libkrb5-3       1.19.2-2ubuntu0.7  (won't fix)     deb             CVE-2018-5709   Negligible 1.6% (82nd)   < 0.1
libkrb5support0 1.19.2-2ubuntu0.7  (won't fix)     deb             CVE-2018-5709   Negligible 1.6% (82nd)   < 0.1
libzstd1        1.4.8+dfsg-3build1 deb             CVE-2022-4899   Low      0.3% (49th)   < 0.1
libgnutls30    3.7.3-4ubuntu1.8   3.7.3-4ubuntu1.9 deb             CVE-2026-42010  Medium    0.1% (34th)   < 0.1
libssl3        3.0.2-0ubuntu1.23  3.0.2-0ubuntu1.25 deb             CVE-2026-45447  High     < 0.1% (26th) < 0.1
libssl3        3.0.2-0ubuntu1.23  (won't fix)     deb             CVE-2025-27587  Low      0.2% (45th)   < 0.1
PS C:\Users\shaim\Documents>
```

Figure 3. Grype output supporting component-level vulnerability review.

Prioritization judgment

- Severity was not treated as the only decision factor; affected asset, reachability, fix availability and exploitation evidence also matter.
- The reviewed highest-severity items were checked against CISA KEV; absence from KEV did not remove the need for remediation.
- Vendor-managed OT applications may not permit local SBOM generation, making contractual SBOM delivery and update cadence important controls.
- Where no SBOM is supplied, maintain software inventory, scan available packages and document uncertainty explicitly.

Detection engineering

OT scheduled-task behavior

An existing Sigma analytic was reviewed for Windows scheduled-task creation associated with Industroyer2-style deployment behavior. The analysis considered event source, ATT&CK; mapping, relevant paths, false positives and the operational significance of alerting in an OT environment.

MFA push fatigue

A defensive Sigma rule was authored for repeated MFA denial/failure activity. The review identified a threshold-evasion weakness: an attacker could remain just below a short-window count. Recommended tuning combines longer-window aggregation with new device, unusual location, unfamiliar IP, impossible travel and subsequent successful authentication.

Telemetry requirements

Scheduled tasks	Windows Security Event ID 4698 or equivalent endpoint telemetry.
MFA fatigue	Identity-provider sign-in and MFA outcome logs.
Container risk	Host, daemon, image, registry and runtime telemetry.
Vulnerability context	SBOM versions, scan results, KEV status and remediation ownership.

Skills demonstrated

Container security	CIS-aligned assessment and configuration-risk interpretation.
Supply-chain security	CycloneDX SBOM generation and vendor SBOM governance.
Vulnerability management	Grype analysis, KEV context and remediation prioritization.
Detection engineering	Sigma review, rule authoring, telemetry requirements and evasion analysis.
OT security	Translated general controls into operational-technology risk context.

Recommendations and conclusion

- Require current SBOMs for critical vendor-managed applications and define update triggers in contracts.
- Automate SBOM generation and scanning in build/release pipelines where source and images are controlled.
- Track vulnerability exceptions with owner, rationale, expiry and compensating controls.
- Validate Sigma analytics against real log schemas before production enablement.
- Measure detection quality and tune thresholds using representative legitimate activity.

Conclusion

The project connected preventive assurance with detective capability. SBOM and vulnerability analysis improved knowledge of what could be exposed, while Sigma analytics addressed suspicious behavior that configuration and patching alone cannot eliminate.

Selected references

CIS Docker Benchmark — <https://www.cisecurity.org/benchmark/docker>
Syft Documentation — <https://github.com/anchore/syft>
Grype Documentation — <https://github.com/anchore/grype>
CycloneDX — <https://cyclonedx.org/>
Sigma Specification — <https://sigmahq.io/docs/>
CISA KEV Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>